

Unit- IV

→ Understanding Computer Forensics

Use of forensic techniques in the investigation of cybercrimes. “Cyber forensics” is a very large domain and addressing it in a single chapter is indeed a challenge. Complex technical aspects involved in digital forensics/computer forensics are not possible to cover in a single chapter. Therefore, this chapter is aimed at only providing a broad understanding about cyber forensics.

Cyber forensics plays a key role in investigation of cybercrime. “Evidence” in the case of “cyber offenses” is extremely important from legal perspective. There are legal aspects involved in the investigation as well as handling of the digital forensics evidence. Only the technically trained and experienced experts should be involved in the forensics activities.

→ Historical Background of Cyber forensics

The Florida Computer Crimes Act was the first computer crime law to address computer fraud and intrusion. It was enacted in Florida in 1978.

“Forensics evidence” is important in the investigation of cybercrimes.

Computer forensics is primarily concerned with the systematic “identification,” “acquisition,” “preservation” and “analysis” of digital evidence, typically after an unauthorized access to computer or unauthorized use of computer has taken place; while the main focus of “computer security” is the prevention of unauthorized access to computer systems as well as maintaining “confidentiality,” “integrity” and “availability” of computer systems.

There are two categories of computer crime: one is the criminal activity that involves using a computer to commit a crime, and the other is a criminal activity that has a computer as a target.

Forensics means a “characteristic of evidence” that satisfies its suitability for admission as fact and its ability to persuade based upon proof.

The goal of digital forensics is to determine the “evidential value” of crime scene and related evidence.

- **Digital Forensics Science**

Digital forensics is the application of analyses techniques to the reliable and unbiased collection, analysis, interpretation and presentation of digital evidence.

1. Computer forensics

It is the lawful and ethical seizure, acquisition, analysis, reporting and safeguarding of data and metadata derived from digital devices which may contain information that is notable and perhaps of evidentiary value to the trier of fact in managerial, administrative, civil and criminal investigations. In other words, it is the collection of techniques and tools used to find evidence in a computer.

2. Digital forensics

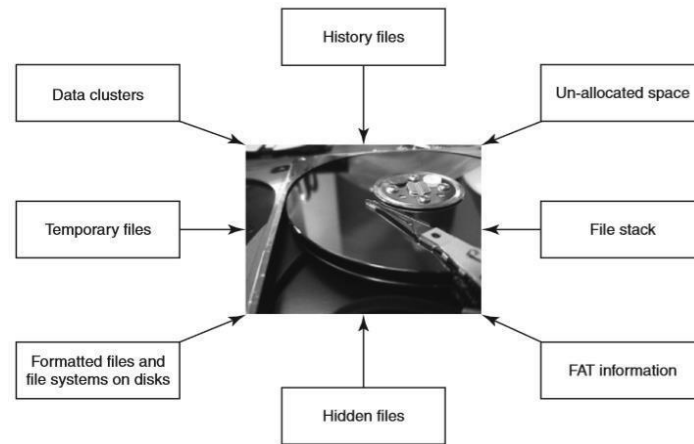
It is the use of scientifically derived and proven methods toward the preservation, collection, validation, identification, analysis, interpretation, documentation and presentation of digital evidence derived from digital sources for the purpose of facilitation or furthering the reconstruction of events found to be criminal, or helping to anticipate unauthorized actions shown to be disruptive to planned operations.

It is difficult to provide a precise definition of “digital evidence” because the evidence is recovered from devices that are not traditionally considered to be computers. Some researchers prefer to expand the definition by including the “collection” and “examination” of all forms of digital data, including the data found in cell phones, PDAs, iPods and other electronic devices.

1. Uncover and document evidence and leads.
2. Corroborate evidence discovered in other ways.
3. Assist in showing a pattern of events (data mining has an application here).
4. Connect attack and victim computers.
5. Reveal an end-to-end path of events leading to a compromise attempt, successful or not.
Extract data that may be hidden, deleted or otherwise not directly available.

The typical scenarios involved are:

1. Employee Internet abuse.
2. Data leak/data breach.
3. Industrial espionage.
4. Damage assessment.
5. Criminal fraud and deception cases;
6. Criminal cases.
7. Copyright violation – more about this is mentioned.



Data seen using forensics tools. FAT means file allocation table.

Using digital forensics techniques, one can:

1. Corroborate and clarify evidence otherwise discovered.
2. Generate investigative leads for follow-up and verification in other ways.
3. Provide help to verify an intrusion hypothesis.
4. Eliminate incorrect assumptions.

• **The Need for Computer Forensics**

The convergence of Information and Communications Technology (ICT) advances and the pervasive use of computers worldwide together have brought about many advantages to mankind. At the same time, this tremendously high technical capacity of modern computers/computing devices provides avenues for misuse as well as opportunities for committing crime.

Chain of custody means the chronological documentation trail, etc. that indicates the seizure, custody, control, transfer, analysis and disposition of evidence, physical or electronic.

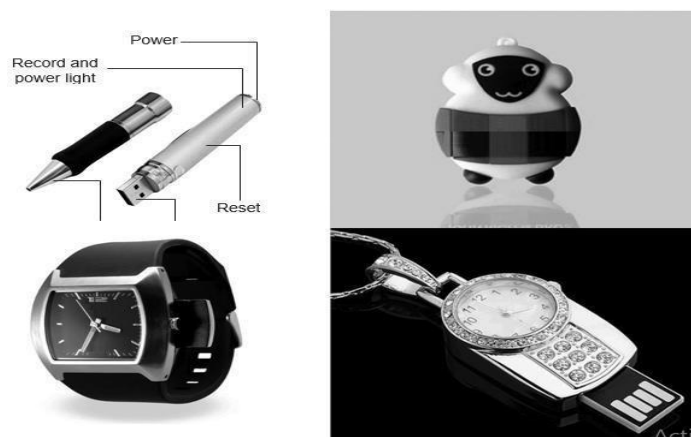


Fig: Hidden and miniaturized storage media.

“Fungibility” means the extent to which the components of an operation or product can be inter- changed with similar components without decreasing the value of the operation or product.

Chain of custody is also used in most evidence situations to maintain the integrity of the evidence by providing documentation of the control, transfer and analysis of evidence.

- **Cyber forensics and Digital Evidence**

Cyber forensics can be divided into two domains:

1. Computer forensics.
2. Network forensics.

Network forensics is the study of network traffic to search for truth in civil, criminal and administrative matters to protect users and resources from exploitation, invasion of privacy and any other crime fostered by the continual expansion of network connectivity.

As compared to the “physical” evidence, “digital evidence” is different in nature because it has some unique characteristics. First of all, digital evidence is much easier to change/manipulate! Second, “perfect” digital copies can be made without harming original.

- **The Rules of Evidence**

This is a very important discussion, especially, for those who are students of legal courses. It was mentioned in that the Indian IT Act amended the Indian Evidence Act. According to the “Indian Evidence Act 1872,” “Evidence” means and includes:

1. All statements which the court permits or requires to be made before it by witnesses, in relation to matters of fact under inquiry, are called oral evidence.
2. All documents that are produced for the inspection of the court are called documentary evidence.

Paper evidence, the process is clear and intuitively obvious. Digital evidence by its very nature is invisible to the eye. Therefore, the evidence must be developed using tools other than the human eye.

There are number of contexts involved in actually identifying a piece of digital evidence:

1. **Physical context:** It must be definable in its physical form, that is, it should reside on a specific piece of media.
2. **Logical context:** It must be identifiable as to its logical position, that is, where does it reside relative to the file system.
3. **Legal context:** We must place the evidence in the correct context to read its meaning. This may require looking at the evidence as machine language, for example, American Standard

Code for Information Interchange (ASCII).

Following are some guidelines for the (digital) evidence collection phase:

1. Adhere to your site's security policy and engage the appropriate incident handling and law enforcement personnel.
2. Capture a picture of the system as accurately as possible.

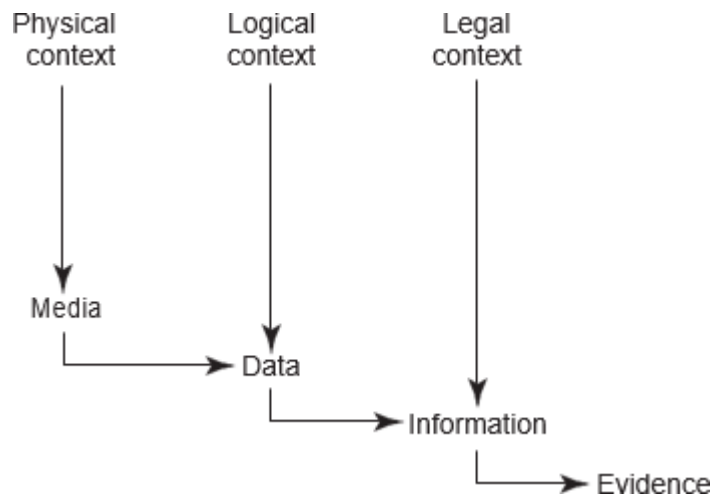


Fig: Path of the digital evidence.

- **Forensics Analysis of E-Mail**

It was mentioned how criminals can use fake mails for various cybercrime offenses. There are tools available that help create fake mails. Forensics analysis of E-Mails is an important aspect of cyber forensics analysis it helps establish the authenticity of an E-Mail when suspected.

Mail server software is a network server software that controls the flow of E-Mail and the mail client software helps each user read, compose, send and delete messages.

E-Mail tracing is done by examining the header information contained in E-Mail messages to determine their source.

- **Digital Forensics Life Cycle**

As per FBI's (Federal Bureau of Investigation) view, digital evidence is present in nearly every crime scene. That is why law enforcement must know how to recognize, seize, transport and store original digital evidence to preserve it for forensics examination.

1. Is admissible.
2. Is authentic.
3. Is complete.
4. Is reliable.
5. Is understandable and believable.

Let us now understand what is involved in the digital forensics process.

• The Digital Forensics Process

The digital forensics process needs to be understood in the legal context starting from preparation of the evidence to testifying. Digital forensics evidence consists of exhibits, each consisting of a sequence of bits, presented by witnesses in a legal matter to help jurors establish the facts of the case and support or refute legal theories of the case.

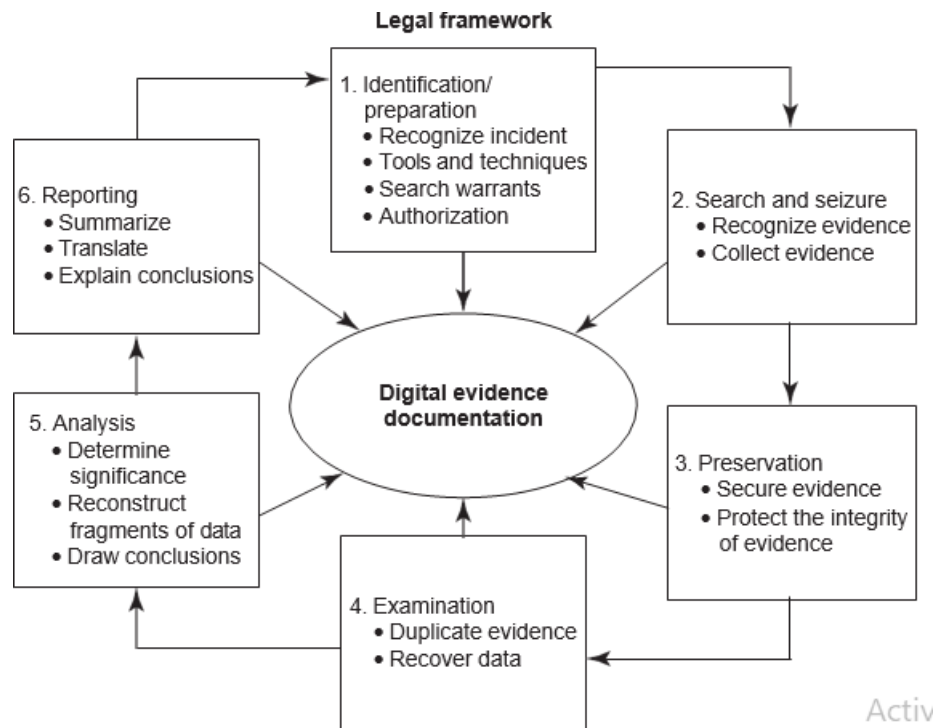


Fig: Process model for understanding a seizure and handling of forensics evidence legal framework.

• The Phases in Computer Forensics/Digital Forensics

The investigator must be properly trained to perform the specific kind of investigation that is at hand. Tools that are used to generate reports for court should be validated. There are many tools to be used in the process.

One should determine the proper tool to be used based on the case. Broadly speaking, the forensics life cycle involves the following phases:

1. Preparation and identification
2. Collection and recording
3. Storing and transporting
4. Examination/investigation
5. Analysis, interpretation and attribution
6. Reporting and
7. Testifying.

To mention very briefly, the process involves the following activities:

1. **Prepare:** Case briefings engagement terms, interrogatories, spoliation prevention, disclosure and discovery planning, discovery requests.
2. **Record:** Drive imaging, indexing, profiling, search plans, cost estimates, risk analysis.
3. **Investigate:** Triage images, data recovery, keyword searches, hidden data review, communicate, iterate.
4. **Report:** Oral vs. written, relevant document production, search statistic reports, chain of custody reporting, case log reporting.
5. **Testify:** Testimony preparation, presentation preparation, testimony.

- **Preparing for the Evidence and Identifying the Evidence**

In order to be processed and applied, evidence must first be identified as evidence. It can happen that there is an enormous amount of potential evidence available for a legal matter, and it is also possible that the vast majority of the potential evidence may never get identified.

- **Collecting and Recording Digital Evidence**

Digital evidence can be collected from many sources. Obvious sources include computers, cell phones, digital cameras, hard drives, CD-ROM, USB memory devices and so on. Non-obvious sources include settings of digital thermometers, black boxes inside automobiles, RFID tags and webpages (which must be preserved as they are subject to change).



Fig: Media that can hold digital evidences.



Fig: Some more media that can hold digital evidences.

- **Storing and Transporting Digital Evidence**

The following are specific practices that have been adopted in the handling of digital evidence:

1. Image computer media using a write-blocking tool to ensure that no data is added to the suspect device;
2. establish and maintain the chain of custody.

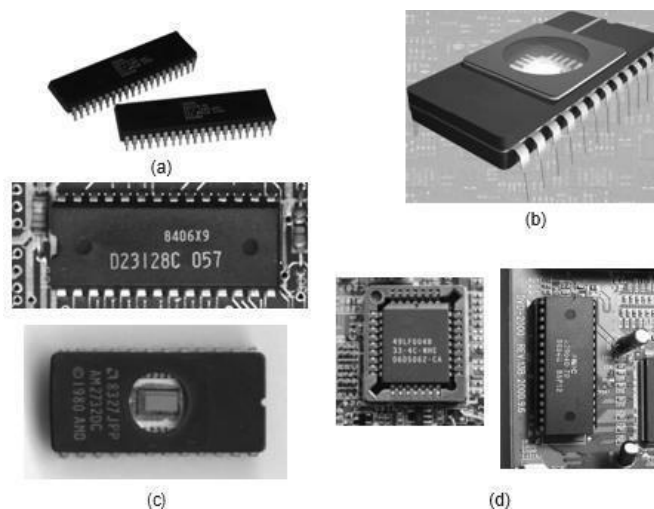


Fig: Embedded memories inside computer. (a) Read-only memory (ROM) chips; (b) erasable programmable read-only memory (EPROM) chip; (c) programmable read-only memory (PROM) chips; (d) electrify erasable programmable read-only memory (EEPROM) chips.

Some of the most valuable information obtained in the course of a forensics examination will come from the computer user. An interview with the user can yield valuable information about the system configuration, applications, encryption keys and methodology. Forensics analysis is much easier when analysts have the user's passphrases to access encrypted files, containers and network servers.

As a general rule, one should not examine digital information unless one has the legal authority to do so. Amateur forensics examiners should keep this in mind before starting any unauthorized investigation.

For the purpose of digital evidence examination, “imaging of electronic media” (on which the evidence is believed to be residing) becomes necessary.

- **Analysis, Interpretation and Attribution**

Analysis, interpretation and attribution of evidence are the most difficult aspects encountered by most forensics analysts. In the digital forensics arena, there are usually only a finite number of possible event sequences that could have produced evidence.

Examples of common digital analysis types include:

1. Media Analysis
2. Media Management Analysis
3. File System Analysis
4. Application Analysis
5. Network Analysis
6. OS Analysis
7. Executable Analysis
8. Image Analysis
9. Video Analysis

- **Reporting**

The following are the broad-level elements of the report

1. Identity of the reporting agency
2. Case identifier or submission number
3. Case investigator
4. Identity of the submitter
5. Date of receipt
6. Date of report
7. Descriptive list of items submitted for examination, including serial number, make and model
8. Identity and signature of the examiner
9. Brief description of steps taken during examination, such as string searches, graphics image searches and recovering erased files
10. Results/conclusions.

- **Testifying**

This phase involves presentation and cross-examination of expert witnesses. Depending on the country and legal frameworks in which a cybercrime case is registered, certain standards may apply with regard to the issues of expert witnesses.

- **Chain of Custody Concept**

1. Chain of custody is the central concept in cyber forensics/digital forensics investigation.
2. The purpose of the chain of custody is that the proponent of a piece of evidence must demonstrate that it is what it purports to be.
3. The chain of custody is a chronological written record of those individuals who have had custody of the evidence from its initial acquisition until its final disposition.

- **Network Forensics**

Recall the mention of network forensics. We have already discussed that open networks can be the source of many network-based cyberattacks. A situation like this leads to the point that network forensics professionals need to understand how wireless networks work and the fundamentals of related technology.

Wireless forensics is a discipline included within the computer forensics science, and specifically, within the network forensics field. The goal of wireless forensics is to provide the methodology and tools required to collect and analyze (wireless) network traffic that can be presented as valid digital evidence in a court of law.

- **Approaching a Computer Forensics Investigation**

From the discussion so far, we can appreciate that computer forensics investigation is a detailed science. Now, let us understand how a forensics investigation is typically approached and the broad phases involved in the investigation. The phases involved are as follows:

1. Secure the subject system (from tampering or unauthorized changes during the investigation);
2. take a copy of hard drive/disk (if applicable and appropriate);
3. identify and recover all files (including deleted files);
4. access/view/copy hidden, protected and temp files;
5. study “special” areas on the drive (e.g., the residue from previously deleted files);
6. investigate the settings and any data from applications and programs used on the system;
7. consider the system as a whole from various perspectives, including its structure and overall contents;
8. consider general factors relating to the user’s computer and other activity and habits in the context of the investigation;

9. create detailed and considered report, containing an assessment of the data and information collected.

- **Typical Elements Addressed in a Forensics Investigation Engagement Contract**

Typically, the following important elements are addressed before while drawing up a forensics investigation engagement contract

1. Authorization
2. Confidentiality
3. Payment
4. Consent and acknowledgment
5. Limitation of liability

Laboratory responsible for any accidental damages to the data or equipment in its possession including but not limited to surface scratches, deformations and cracks.

1. **Customer's representation:** Customer needs to warrant the forensics laboratory that he/she is the owner of, and/or has the right to be in possession of, all equipment/data/media furnished to the laboratory and that collection, possession, processing and transfer of such equipment/data/media are in compliance with data protection laws to which customer is subject to.
2. **Legal aspects/the law side:** Both the parties need to agree that the agreement shall be governed by prevailing law in every particular way including formation and interpretation and shall be deemed to have been made in the country where the contract is signed.
3. **Data protection:** The computer forensics laboratory (engaged in the investigation) will hold the information that the customer has given verbally, electronically or in any submitted form for the purpose of the forensics investigation to be carried out as per contracted services from the forensics laboratory.
4. **Waiver/breach of contract:** The waiver by either party of a breach or default of any of the provisions on this agreement by either party shall not be construed as a waiver of any succeeding breach of the same or other provisions, nor shall any delay or omission on the part of either party to exercise or avail itself of any right, power or privilege that it has, or may have hereunder operates as a waiver of any breach or default by either party.

→ Solving a Computer Forensics Case

These are just some broad illustrative steps and they may vary depending on the specific case in hand.

1. Prepare for the forensics examination.
2. Talk to key people to find out what you are looking for and what the circumstances surrounding the case are.
3. If you are convinced that the case has a sound foundation, start assembling your tools to collect the data in question. Identify the target media.
4. Collect the data from the target media. You will be creating an exact duplicate image of the device in question. To do this, you will need to use an imaging software application like the commercial in Case or the open-source Sleuth Kit/Autopsy.
5. To extract the contents of the computer in question, connect the computer you are investigating to a portable hard drive or other storage media and then boot the computer under investigation according to the directions for the software you are using.
6. When collecting evidence, be sure to check E-Mail records as well. Quite often, these messages yield a great deal of information.
7. Examine the collected evidence on the image you have created. Document anything that you find and where you found it.
8. Analyze the evidence you have collected by manually looking into the storage media and, if the target system has a Windows OS, check the registry.
9. Report your findings back to your client. Be sure to provide a clear, concise report; this report may end up as evidence in a court case.

- **Setting up a Computer Forensics Laboratory Understanding the Requirements**

There are four broad types of requirements, namely, the physical space, the hardware equipment, the software tools and the forensics procedures to be followed to aid those involved in the cybercrime investigation.



Fig: Cyber forensics laboratory – 1



Fig: Cyber forensics laboratory – 2

Apart from the physical space requirement, another key requirement for a computer forensics laboratory is the hardware items. The laboratory requires a number of computers,

including a network server with a large storage capacity (preferably configured for the standard removable hard drives).

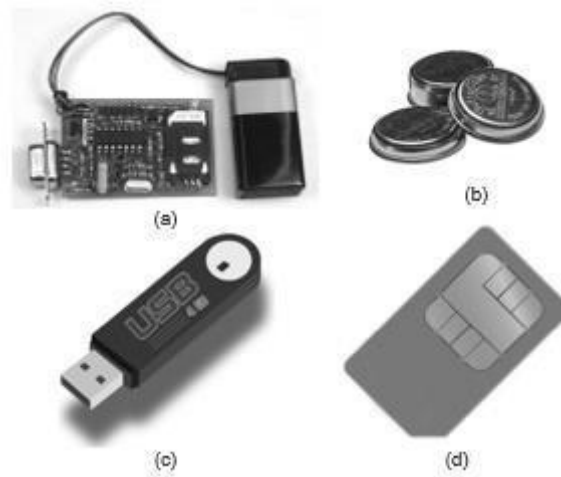


Fig: (a) SIM card reader, (b) iButtons, (c) flash memory, (d) SIM card.

On the software side, there are several requirements for setting up a forensics laboratory. The standard forensics software package, such as EnCase, Web Case, Forensics Tool Kit, Password Recovery Tool Kit, etc. are expensive products.

The main issues that are attacked when evidence is presented in a court of law are credentials and methodology. In some countries, the court may prefer the forensics evidence from government appointed and/or neutral party laboratories rather than the evidence from private agencies where opportunities for manipulation/exploitation are perceived.

- **Computer Forensics and Steganography**

Steganography is the art of information hiding. The threat raised by steganography is very real. Its use is not easy to detect or intercept, as the information does not need to be broadcast across the Internet. the hidden message can reside unsuspectingly on a website, for example, and can be viewed from around the world.

Steganography is the art of information hiding. The threat raised by steganography is very real. Its use is not easy to detect or intercept, as the information does not need to be broadcast across the Internet. The hidden message can reside unsuspectingly on a website, for example, and can be viewed from around the world.

Rootkits

The term rootkit is used to describe the mechanisms and techniques whereby malware including viruses, Spyware and Trojans attempt to hide their presence from Spyware blockers, antivirus and system management utilities.

Information Hiding

Let us now have an overview of some characteristics of information hiding and then we discuss about analysis methods for determining the existence of and potential locations of hidden information.

➔ Relevance of the OSI 7 Layer Model to Computer Forensics

The OSI 7 Layer Model is useful from computer forensics perspective because it addresses the network protocols and network communication processes. The basic familiarity with the OSI 7 Layer Model is assumed for the discussion in this section.

Step 1: Foot Printing

Foot printing includes a combination of tools and techniques used to create a full profile of the organization's security posture. These include its domain names, IP addresses and network blocks.

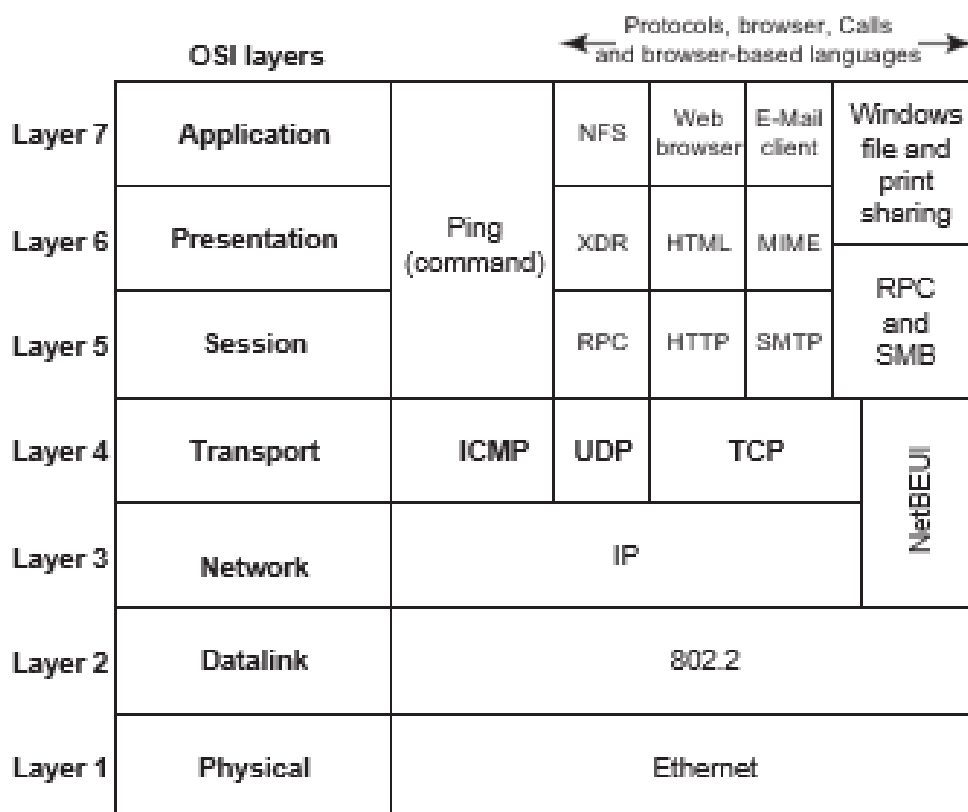


Fig: The OSI 7 Layer Model with Internet Protocols.

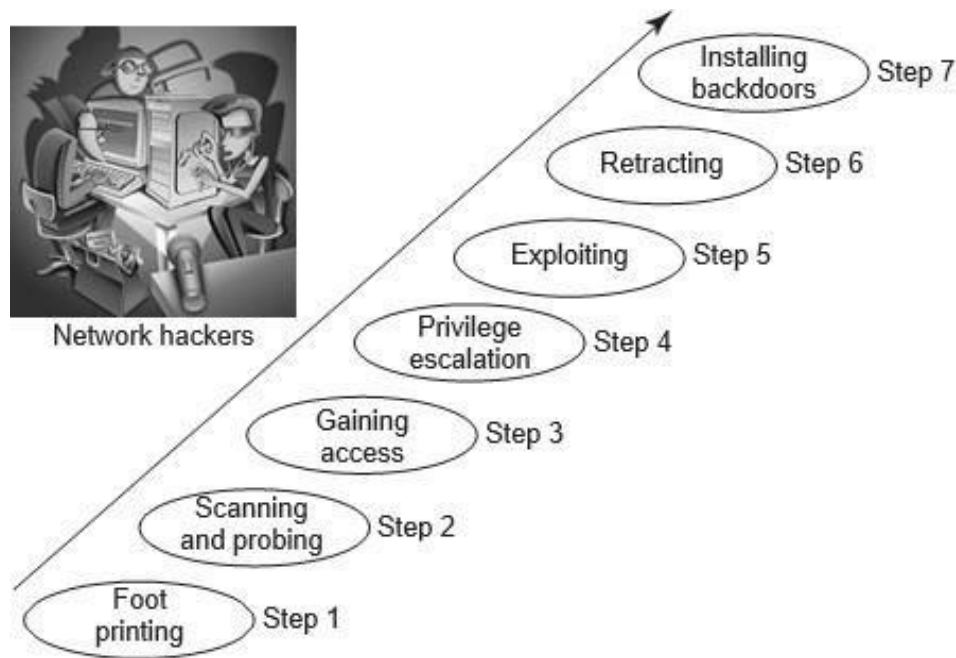


Fig: Network hacking steps

Step 2: Scanning and Probing

The hacker will typically send a ping echo request packet to a series of target IP addresses. As a result of this exploratory move by the hacker, the machines assigned to one of these IP address will send out echo response thereby confirming that there is a live machine associated with that address. Similarly, a TCP scan sends a TCP synchronization request to a series of ports and to the machines that provide the associated service to respond.

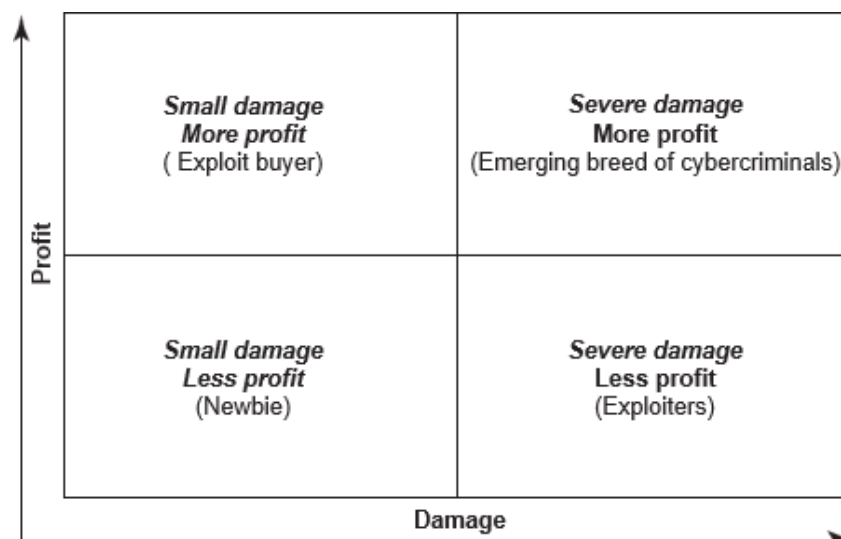


Fig. Hacker categories (profit and damage).

Step 3: Gaining Access

The hacker's ultimate goal is to gain access to your system so that he/she can perform some malicious action, such as stealing credit card information, downloading confidential files or manipulating critical data.

Step 4: Privilege

When a hacker gains access to the system, he will only have the privileges granted to the user or account that is running the process that has been exploited.

Step 5: Exploit

Gaining root access gives the hacker full control on the network. Every hacker seems to have his/her own reasons for hacking. Some hackers do it for fun or a challenge, some do it for financial gain and others do it to "get even".

Step 6: Retracting

There are many reasons that drive cybercriminals to hacking.

Step 7: Installing Backdoors

Finally, most hackers will try creating provisions for entry into the network/hacked system for later use. this, they will do by installing a backdoor to allow them access in the future.

➔ Computer Forensics from Compliance Perspective

With the rampant use of the Internet, there is so much at stake; corporate data is not safe anymore given that almost all information assets lie on the corporate networks. We are in the era of Net-centric digital economy.

Criminals can gather small pieces about you, about your confidential data to generate what is known as "digital persona," that is, they keep track about your Internet activities, what resides on your corporate networks, etc.

- **The Regulatory Perspective for Forensics at the International Level**

These laws/regulations specify investigation and response to security breaches or policy violations. Computer forensics makes it easier to meet these requirements.

These laws/legislations become relevant in the context of forensics with cybercrimes.

1. **The Sarbanes Oxley Act (SOX):** The Act was enacted to fight corporate fraud.
2. **California SB 1386**
3. **Gramm-Leach Bliley Act (GLBA)**

The Safeguards Rule of GLB calls for financial institutions to:

- a) Ensure the security and confidentiality of customer information;
- b) Protect against any anticipated threats or hazards to the security or integrity of such information;
- c) Protect against unauthorized access to or use of such information that could result in substantial harm or inconvenience to any customer.

4. **HIPAA (Health Insurance Portability and Accountability Act of 1996)**

HIPAA has the primary goal for healthcare providers to improve the privacy and security of their clients' medical information.

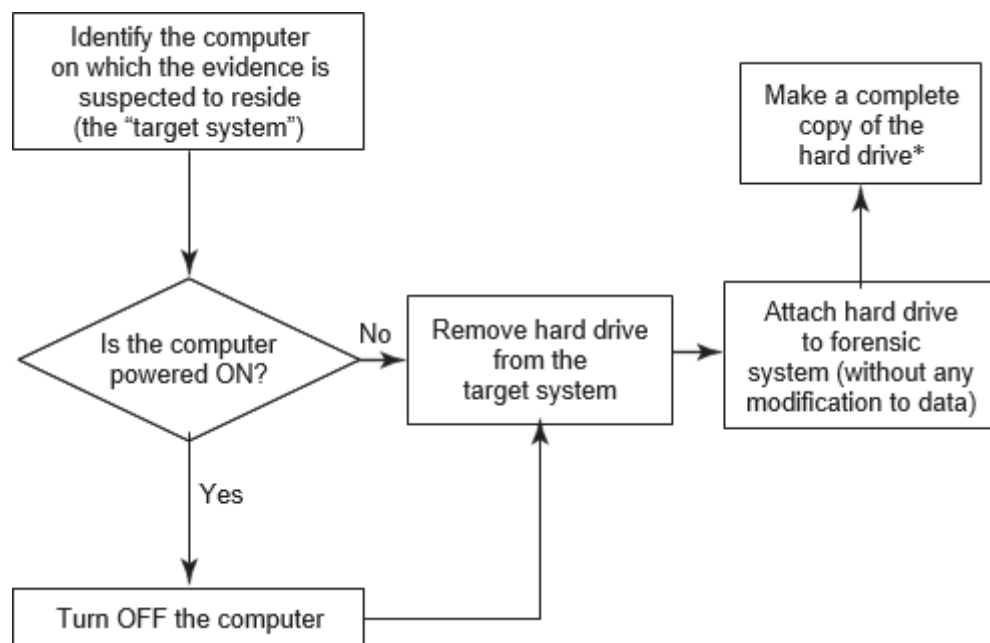


Fig: Traditional approach to forensics analysis. *denotes tools/devices mentioned

